



eSamithi Web

Requirements & Redesign Specification

Version 1.0 · 2026-09-09 · Approved for build (Phase 0) · Azynta Technologies

About this document

eSamithi replaces its Electron office application with a browser application at `app.esamithi.com`, redesigned on a documented design system, installable as a PWA and wrapped by a thin desktop shell. The tenant API, the databases and the samithi join codes stay exactly as they are; only a browser-grade session layer is added, additively. This document is the requirements, architecture and delivery contract for that programme, including the safety protocol that protects the society already in production.

Version	1.0
Date	2026-09-09
Status	Approved for build (Phase 0)
Product	the eSamithi office application, migrated from the Electron desktop app to <code>https://app.esamithi.com</code>
Depends on	<code>MULTI-SAMITHI-ARCHITECTURE.md</code> (tenant API, directory service, DB-per-samithi) · <code>SUPER-ADMIN-PANEL-REQUIREMENTS.md</code> (platform console, impersonation)
Supersedes	<code>UI-ENHANCEMENT-PLAN.md</code> — every open item in it is absorbed by §3 and §4 of this document
Prepared for	Azynta Technologies · eSamithi

Contents

0. Executive summary

1. Purpose, scope and decisions

- 1.1 Goals
- 1.2 Non-goals (explicitly out of scope for v1.0)
- 1.3 Decisions locked with the owner
- 1.4 Actors and personas

2. Current state (as built, September 2026)

- 2.1 Components
- 2.2 What the desktop app actually is
- 2.3 Verified gaps that shape this design
- 2.4 What this programme deliberately leaves exactly as it is

3. Functional requirements

- FR-1 · Access, identity and session
- FR-2 · Application shell and navigation
- FR-3 · Dashboard
- FR-4 · Members
- FR-5 · Incomes and expenses (the ledger)
- FR-6 · Loans
- FR-7 · Wallet hub (wallets, transfers, fixed deposits, assets)
- FR-8 · Reports
- FR-9 · Messages (announcements, member requests, Puruka administration)
- FR-10 · Attendance
- FR-11 · Settings and users
- FR-12 · Printing and exports
- FR-13 · Localisation (Sinhala / English)
- FR-14 · PWA and the desktop shell
- FR-15 · Support mode (operator impersonation) — Phase 5

4. UX redesign specification

- 4.1 Design principles
- 4.2 Visual identity and colour tokens
- 4.3 Typography
- 4.4 Spacing, radii, elevation, focus
- 4.5 Motion system
- 4.6 Component inventory
- 4.7 Application shell and page templates

- 4.8 Route map and URL state
- 4.9 Interaction patterns
- 4.10 UX upgrades beyond desktop parity
- 4.11 Accessibility
- 4.12 Dark mode and print

5. Non-functional requirements

6. Architecture

- 6.1 Overview
- 6.2 Repository structure
- 6.3 Stack and rationale
- 6.4 Same-origin topology and multi-server routing
- 6.5 Authentication and session protocol
- 6.6 Database changes (additive, guarded, idempotent)
- 6.7 API contract
- 6.8 State, caching and invalidation
- 6.9 Printing
- 6.10 PWA
- 6.11 Desktop 1.3.8 thin shell

7. Security requirements

8. Feature-parity matrix and sign-off

9. Testing and quality strategy

10. Delivery plan

11. Deployment, operations and production-safety protocol

- 11.1 Hosting and release mechanics
- 11.2 Production safety protocol (every server change)
- 11.3 Rollback
- 11.4 Feature flags and environment

12. Risks and mitigations

13. Open decisions and owner actions

Appendix A · Backend work list (all additive)

Appendix B · Infrastructure work list

Appendix C · Web package scripts and conventions

Appendix D · Glossary

Appendix E · Reference files in the repository

0. Executive summary

eSamithi today has three clients on one multi-tenant API: the **member mobile app** (Google Play), the **office desktop app** (Electron, Windows, v1.3.7) and the **operator console** (`console.esamithi.com`). This document specifies the replacement of the office desktop app by a **browser application at `app.esamithi.com`** , with a complete UI/UX redesign, while the one society already in production keeps working without interruption.

Why now. The desktop app must be installed and updated on every office PC. The September 2026 incident (a bundled dev configuration silently pointing field installs at the test server) showed how fragile that is. A web app removes installers and update feeds, works on any PC or tablet, lets the office and the operator's support workspace share one codebase, allows far shorter and revocable sessions, and gives the product a modern, professional face for the villages it is being sold to.

Why it is doable with low risk. The desktop app is already a thin client: every rule and record lives in the tenant API. A browser build of the same renderer already runs today as the operator's support workspace. Migrating therefore means (1) a new front-end on a real design system, (2) a browser-grade session layer the API does not have yet, and (3) hosting. **There is no data migration at all** — same endpoints, same databases, same samithi join codes.

What stays untouched. Production data, the live client's desktop installs (1.3.7 keeps working throughout), every existing endpoint contract (including `POST /auth/login` byte-for-byte), the `DEFAULT_TENANT` fallback for header-less legacy clients, the `JWT_SECRET` , the mobile app and the console.

Locked decisions. One public URL with a samithi-code login (like the desktop today) · office web app first, console restyle and mobile later · React 19 + TypeScript + Vite, Tailwind v4 + shadcn/ui, TanStack Router/Query/Table, Motion, PWA · refresh token in an HttpOnly cookie with a 15-minute in-memory access token, same-origin behind nginx · the eS brand evolved, not replaced · full feature parity first, then a pilot with the live society side by side with the desktop, then cut-over · desktop 1.3.8 becomes a thin shell that loads the web app.

Delivery. Six phases, ≈ 12–13 development weeks for one developer working with an AI pair, plus 2–3 calendar weeks of pilot. Nothing touches the production server before Phase 4, and every production step is backed by a fresh database dump and a tested rollback.

Key numbers	
Office modules to reach parity	11 (auth, dashboard, members, incomes, expenses, loans, wallet hub, reports, messages, attendance, settings)
Existing tenant endpoints reused unchanged	≈ 110 (23 route files)
New endpoints (all additive)	7 staff-session endpoints + 1 admin password reset + 1 dashboard trends (P2)
New database objects (additive, guarded)	2 tables + 4 nullable/defaulted columns on <code>users</code>
i18n keys carried over	≈ 890 per language (English + Sinhala), plus web-only keys
Societies affected in production	1 live (Maranadhara Samithi, <code>samithi01</code>) — pilot partner

1. Purpose, scope and decisions

1.1 Goals

1. **Zero-install office application.** Any modern browser on Windows, macOS, Linux, ChromeOS or Android tablet opens `https://app.esamithi.com`, enters the samithi code and signs in. No installer, no update feed, no local configuration file.
2. **Full feature parity with desktop 1.3.7** before anyone is asked to switch (see the parity matrix in §8).
3. **A redesigned, professional UI/UX** — a documented design system (colour, type, spacing, motion), responsive layouts, purposeful animation for human feedback, and first-class Sinhala.
4. **A browser-grade session model** — short access tokens, rotating refresh tokens, logout everywhere, lockout and rate limiting — added to the API without changing what existing clients see.
5. **Safe coexistence.** The live society can use the desktop and the web app at the same time during the pilot; nothing forces a switch until the owner signs off.
6. **One front-end for two audiences.** The same web app later hosts the operator's audited support workspace (`/support`), retiring the separate `/workspace/` bundle.
7. **Installable PWA and a thin desktop shell** so offices that prefer "an app on the desktop" keep that feeling.

1.2 Non-goals (explicitly out of scope for v1.0)

- Changes to the member mobile app or its API surface (`/me` , `/member-auth` , `/puruka` member endpoints).
- Redesign of the operator console (it will be restyled on the same tokens later; only the handoff into the new `/support` route changes in Phase 5).
- New business features beyond parity, except the small P1/P2 UX upgrades listed in §4.10 that need no new business rules.
- Offline data entry (an offline-tolerant attendance queue is a P3 candidate).
- Server-side PDF generation, SMS gateway, billing or self-signup.
- Rotating the tenant `JWT_SECRET` , changing the DB-per-samithi model, or any destructive schema change.

1.3 Decisions locked with the owner

Topic	Decision	Rationale
URL model	One public <code>https://app.esamithi.com</code> ; login = samithi join code → username/password	Mirrors the desktop flow officers already know; one certificate, one deployment; societies on other servers are redirected automatically
Scope order	Office web app first; console restyle + support handoff later; mobile untouched	Concentrates effort on the client being replaced; the console already works
Session transport	15-minute access JWT held in memory + rotating refresh token in an <code>HttpOnly; Secure; SameSite=Strict</code> cookie, reuse detection, logout everywhere	Not readable by scripts (XSS-resistant), revocable, survives reload, works identically inside the Electron shell; CSRF impossible under <code>SameSite=Strict</code> + custom header

Topic	Decision	Rationale
Origin topology	SPA and API are same-origin : nginx on the app host proxies <code>/api/</code> and <code>/directory/</code>	Required for the cookie model; removes CORS from the picture; already the pattern the console uses
Stack	React 19 + TypeScript + Vite · Tailwind v4 (<code>@theme</code> tokens) + shadcn/ui (Radix) · TanStack Router, Query, Table · Motion · react-hook-form + Zod · sonner · cmdk · vite-plugin-pwa · Vitest + Testing Library + MSW · Playwright + axe · Lighthouse CI · recharts stays	Latest mainstream tooling with long support horizons; owned component code (shadcn) instead of a locked-in UI kit; typed URLs; the team already uses TanStack Query in the mobile app
Visual identity	Evolve the existing eS brand (blue <code>#1E64D4</code> scale, navy <code>#0F172A</code> , eS squircle mark, Inter + Noto Sans Sinhala)	Recognisable to existing users and consistent with the Play Store listing and console
Desktop app	Feature-frozen at 1.3.7; 1.3.8 = thin Electron shell that loads the web URL; then fades out	Offices keep a desktop icon; the shell needs no business code; rollback remains possible
Rollout	Parity → private preview → pilot with Maranadhara Samithi alongside 1.3.7 → cut-over → shell	The live society is never forced to switch before it is ready
Production safety	Additive migrations only; frozen endpoint contracts; testbed soak ≥ 3 days; manual production deploys after a fresh <code>mysqldump</code> ; tested rollback for every step	Absolute constraint set by the owner

1.4 Actors and personas

Persona	Role in the society	Context	Needs most
Treasurer (කාණ්ඩාගාරික) — <code>admin</code> or <code>user</code>	Runs the counter on collection day: fees, fines, loan repayments, receipts	Office PC or laptop, USB barcode scanner, dot-matrix or inkjet printer, often in Sinhala	Speed and certainty: find a member in one keystroke, record and print in seconds, never lose a day's entries, see loans and arrears at a glance
Secretary (ලේකම්) — <code>user</code>	Member register, dependents, meetings, attendance, death notices, letters	Same PC, sometimes a tablet at the meeting hall	Clean member records, quick attendance marking, printable statements and letters
President / committee — <code>viewer</code>	Oversight; reads reports at meetings and the AGM	Any device, occasionally	Trustworthy figures, printable monthly/annual reports, no way to change anything by accident
Operator (support) — platform super-admin	Onboards societies; enters a society's workspace on request with a full audit trail	Console on a laptop	The same screens the office sees, clearly marked as a support session, with an exit
Member (indirect)	Uses the mobile app; receives receipts, notices and requests answered by the office	Phone	Consistency between what the office records and what the app shows (same API, so automatic)

2. Current state (as built, September 2026)

2.1 Components

Component	Where	Version / state
Office desktop app	<code>src/</code> (Electron 3x + React 19 + Vite, HashRouter), NSIS installer, electron-updater feed at <code>/updates/</code> on the API host	1.3.7 — feature-frozen at parity once the web pilot starts
Support workspace (browser build of the renderer)	<code>vite.web.config.ts</code> → <code>dist-web</code> , served at <code>console.esamithi.com/workspace/</code> , 78-method fetch shim in <code>src/renderer/src/workspace/shim.ts</code>	Live — the proof that the renderer runs in a browser; it is also the de-facto REST contract
Tenant API	<code>server/</code> (Express 4, MySQL 8.4, AsyncLocalStorage tenant pools), <code>X-Samithi</code> header selects the tenant, <code>DEFAULT_TENANT</code> for header-less legacy clients	Migrations <code>000_base_schema</code> , <code>004 – 013</code> applied on every tenant (INFORMATION_SCHEMA-guarded, idempotent)
Platform (control plane) + operator console	<code>platform/</code> , <code>src/admin/</code> on the testbed, <code>console.esamithi.com</code> ; public directory <code>GET /directory/v1/resolve/:code</code>	Live; manages both servers
Member mobile app	<code>mobile/</code> (Expo SDK 57), Google Play production	1.3.1 (vc5 live, vc6 awaiting upload)
Production server	141.147.75.132 (<code>api.esamithi.com</code> , Oracle ARM, 1 vCPU / 6 GB), stack <code>/opt/esamithi-stack</code> , code <code>/opt/esamithi-server</code> , nginx 1.27 + api + MySQL 8.4 in Docker	Hosts Maranadhara Samithi (<code>samithi01</code> , join code <code>SAM-4217</code> , ≈ 148 members) — the live client
Testbed server	212.227.103.150 (<code>console.esamithi.com</code>), stack <code>/opt/esamithi</code> , code <code>/opt/server</code>	Hosts test societies (<code>test01</code> , <code>demo = DEM-9361</code> , ...), the platform and the console; CI deploys here

2.2 What the desktop app actually is

The renderer talks to the main process over IPC; the main process forwards every call to the tenant API with `X-Samithi` and a bearer token. There is no local business logic and no local database in use (the SQLite module is dead code). Receipt numbers (`INC-`, `EXP-`, `LNP-`, `LN-`) are derived on the client from record ids; CSV exports are built on the client with a UTF-8 BOM. Everything the web app needs from the desktop is therefore **presentation logic**, which is being redesigned anyway, plus a handful of pure utilities that will be ported with tests (§6.2).

2.3 Verified gaps that shape this design

- Staff authentication is a single 24-hour JWT: **no refresh, no logout, no rate limit, no lockout**, and passwords are stored as **unsalted SHA-256** (`auth.routes.js`, `users.routes.js`, `internal.routes.js`, `provision-tenant.js`, `ci-e2e.sh`). `bcryptjs`, `express-rate-limit` and `helmet` are already dependencies; `cookie-parser` is not.
- `cors()` is wide open (`Access-Control-Allow-Origin: *`) without credentials; helmet already emits CSP/HSTS on API responses.
- The API never sets `trust proxy`; behind the nginx container every request has the same `req.ip`, so the existing member-PIN rate limiter already shares one bucket per tenant.

- Testbed societies resolve to a plain-HTTP `api_url` (`http://212.227.103.150/api/v1`), which a browser on an HTTPS page cannot call directly (mixed content). The live directory slug for the demo society is `demo` (the repo's `tenants.json` says `demo02`).
- `app.esamithi.com` has no DNS record yet; `api.esamithi.com` resolves and serves HSTS; the only TLS host on the testbed is `console.esamithi.com` .
- The desktop CSS has no responsive breakpoints, 27 classes used but never defined, and three different migration-mode predicates (the server rule is `migration_completed !== 'true'`).
- Several strings are still English in the Sinhala UI: the offline bar, session-expired toast, discard dialog, a11y labels, raw enum badges (transaction, loan, wallet, FD, asset status), CSV headers, form placeholders and the building/asset/bill option constants (§3.13).
- `POST /users` does not validate `role` , so a `viewer` account can already be created through the API even though the UI never offers it.

2.4 What this programme deliberately leaves exactly as it is

Tenant databases and their schemas (only additive objects are appended) · every business endpoint and its response shapes · `POST /auth/login` and the 24-hour bearer token the desktop uses · `DEFAULT_TENANT` header-less fallback · the tenant `JWT_SECRET` (per-server impersonation secrets depend on it) · the mobile app · the operator console (until the Phase 5 handoff) · the desktop update feed (used to ship the 1.3.8 shell).

3. Functional requirements

Priorities follow MoSCoW: **M** must have for v1.0 (parity or safety), **S** should have (ships in v1.0 unless it slips the pilot), **C** could have (post-pilot). "Desktop" in an acceptance criterion means desktop 13.7 behaviour, which is the reference for parity. Every user-visible string is available in English and Sinhala unless stated otherwise.

FR-1 · Access, identity and session

ID	Requirement	Pri	Acceptance criteria
FR-1.1	Samithi code first. The login screen asks for the samithi join code before any credentials. The code is resolved through the directory (<code>/directory/v1/resolve/:code</code>), the society name is shown, and the code is remembered on the device with a visible "Change samithi" action	M	Credentials cannot be entered before a valid code; unknown code shows the directory's error text; suspended society shows a clear message; <code>?code=XXX</code> pre-fills the code (used by cross-server redirects and onboarding links)
FR-1.2	Credential sign-in with username and password via the new <code>POST /auth/session</code> (never <code>/auth/login</code>)	M	Same credentials as the desktop work; failure text is the generic "Invalid username or password"; the password field is never autofilled with a value from another samithi
FR-1.3	Session model. Access token (15 min) lives only in memory; a rotating refresh token lives in an <code>HttpOnly</code> cookie. Silent refresh keeps the user signed in for up to 12 h of idleness and at most 24 h per sign-in	M	Reload within the idle window restores the session without a prompt; no token is present in <code>localStorage / sessionStorage</code> ; DevTools shows the cookie as <code>HttpOnly</code> , <code>Secure</code> , <code>SameSite=Strict</code> , path <code>/api/v1/auth</code>
FR-1.4	In-place re-authentication. When the session cannot be refreshed, a dialog asks for the password only (samithi and username preserved); on success the failed request is retried and unsaved form state is kept	M	A treasurer half-way through an income entry loses nothing; cancel returns to the login screen
FR-1.5	Sign out revokes the current session; sign out everywhere revokes all sessions of the user; other open tabs sign out immediately	M	Refresh with the old cookie fails after sign-out; the sessions list is empty after "everywhere"; a second tab shows the login screen within 1 s
FR-1.6	Sessions list. The user sees their own active sessions (device/browser, IP, first seen, last used, current marker) and can revoke any of them	S	Revoking another session makes its next refresh fail; the current session is marked
FR-1.7	Change own password (current + new, strength rule: ≥ 8 chars, not equal to username) revokes all other sessions	M	Old password no longer works; the current tab stays signed in; other sessions are gone
FR-1.8	Admin password reset for another user (<code>PATCH /users/:id/password</code>) revokes that user's sessions	M	Only <code>admin</code> sees the action; target user must sign in again
FR-1.9	Brute-force protection. Per IP+samithi rate limit on failed logins (30 / 15 min) and an account lockout after 10 consecutive failures for 15 minutes (HTTP 423), shown with the remaining time; a successful login resets the counter	M	11th wrong attempt shows the lockout message even with the right password; desktop logins are unaffected until cut-over (<code>STAFF_LOCKOUT_SCOPE=web</code>)

ID	Requirement	Pri	Acceptance criteria
FR-1.10	Roles. <code>admin</code> , <code>user</code> , <code>viewer</code> as today; <code>viewer</code> never sees write controls and the server keeps enforcing read-only	M	Role badge in the top bar; every mutating button hidden for <code>viewer</code> ; a forged request still gets 403
FR-1.11	Maintenance and status messages from the directory (<code>maintenance.message</code> , <code>status</code>) appear on the login screen and as a banner inside the app	S	Console-set maintenance text is visible within one page load
FR-1.12	Other-server redirect. If the resolved society is hosted on another eSamithi server, the app explains this and redirects to that server's app URL with the code pre-filled	M	Demo society (testbed) entered on the production app lands on <code>console.esamithi.com/app/?code=DEM-9361</code> ; no API call ever crosses origins
FR-1.13	Desktop contract frozen. <code>POST /auth/login</code> request/response and the 24 h bearer token are unchanged for desktop 1.3.7	M	Automated contract test in CI; verified on the production smoke after each deploy
FR-1.14	Support mode (operator impersonation) opens the same app at <code>/support</code> with the platform-issued token, a permanent red banner, a 60-minute countdown and an Exit action that revokes the session on the platform	S (Phase 5)	Identical to the current workspace behaviour; the office user's own session is never affected

FR-2 · Application shell and navigation

ID	Requirement	Pri	Acceptance criteria
FR-2.1	Collapsible sidebar with the eleven modules, grouped (Money · People · Society · System), active state, collapsed state persisted	M	Same modules as the desktop; state survives reload
FR-2.2	Top bar: society name + join-code chip, role badge, command palette button, language switch, theme toggle, user menu (change password, sessions, install app, sign out)	M	All actions reachable by keyboard
FR-2.3	Command palette (Ctrl/⌘ K): member search (name / member ID / NIC), navigation, and quick actions (record income for member, new expense, new loan, new event)	M	Member appears in ≤ 300 ms after typing 3 characters on the testbed; Enter opens Member 360
FR-2.4	Banner stack under the top bar: migration mode, offline (with Retry), new version available, maintenance, support session	M	Banners never overlap content; each has a distinct colour and icon
FR-2.5	Deep links and URL state. Every list filter, tab and detail page is addressable (<code>/members/123</code> , <code>/incomes?from=...&type=...</code>) and back/forward behave	M	Copying the URL to another tab reproduces the view
FR-2.6	Responsive layout: full sidebar ≥ 1280 px, icon rail 1024–1279, off-canvas drawer 768–1023, phone ≤ 767 best-effort (read and record, no printing guarantees)	M (≥ 768) / S (phone)	Tablet in landscape can run a full counter day
FR-2.7	Keyboard shortcuts on counter screens: <code>/</code> focus search, <code>N</code> new record, <code>Esc</code> close, <code>Enter</code> prints from a preview; shortcuts listed under <code>?</code>	S	No shortcut fires while typing in a field

ID	Requirement	Pri	Acceptance criteria
FR-2.8	Unsaved-changes guard on every form (sheet, dialog, page navigation, tab close)	M	Browser "leave page?" prompt on reload with a dirty form
FR-2.9	Error boundaries per route with a friendly recovery card and a "report" that posts to <code>/client-errors</code> (existing endpoint)	M	A rendering error in one module never blanks the shell
FR-2.10	Footer shows <code>web vX.Y.Z · api vA.B</code> (API version from <code>/health</code>)	S	Matches the deployed versions

FR-3 · Dashboard

ID	Requirement	Pri	Acceptance criteria
FR-3.1	KPI grid: active members, liquid funds, fixed deposits, loans outstanding — each linking to its module	M	Values identical to the desktop at the same instant (same <code>/dashboard/stats</code>)
FR-3.2	"Needs attention" card: overdue loans, FDs maturing within 30 days, members without the membership fee (hidden in migration mode), each linking to the matching arrears sub-tab	M	Links land on the right tab with the right filter in the URL
FR-3.3	Quick actions: record income, record expense, issue loan, new event, add member	M	Each opens the corresponding form pre-focused
FR-3.4	Monthly cash-flow chart (existing <code>chartData</code>) with Sinhala month labels in Sinhala mode	M	Bars match the monthly report totals
FR-3.5	Recent activity list (last ledger entries and loan events) with links	S	Newest first, 10 items
FR-3.6	12-month trend sparklines on KPI cards (<code>GET /dashboard/trends</code> , new)	S (P2)	Trend endpoint returns 12 rows; hidden gracefully if unavailable
FR-3.7	Manual refresh and 60 s automatic refresh while the tab is visible	M	Refresh spinner never blocks interaction

FR-4 · Members

ID	Requirement	Pri	Acceptance criteria
FR-4.1	Member list with server-side search by name, member ID or NIC, status filter, pagination (15 / 30 / 50) and sortable columns	M	Search hits the existing <code>?search=</code> semantics; typing "0042" finds member ID 0042 and NICs containing it
FR-4.2	Add / edit member with every desktop field: society ID, names, NIC, DOB, gender, phone (10 digits), address, bank + account (bank list from <code>constants/banks.ts</code>), joined date, status, notes; dependents with relationship and auto-age	M	Every desktop validation message reproduced; async uniqueness checks on society ID and NIC (<code>/members/check-unique</code>) shown inline
FR-4.3	Member 360 page (<code>/members/:id</code>): identity header with status, tabs — Overview (profile), Statement (lazy, <code>/members/:id/statement</code>), Loans & guarantees, Dependents, App access; actions — record payment, issue loan, edit, print statement	M	Statement figures equal the desktop View dialog; guarantees list shows the loans the member guarantees

ID	Requirement	Pri	Acceptance criteria
FR-4.4	Delete member blocked when transactions exist; otherwise typed confirmation	M	Server rule surfaces verbatim; confirmation requires typing the member's society ID
FR-4.5	Scan card: exact society-ID match opens the member; otherwise a single fuzzy hit opens, multiple hits list	M	Scanner input keeps focus after each read; unknown ID gives an audible/visual miss
FR-4.6	Mobile-app access (enable, disable, reset PIN) visible to <code>admin</code> only	M	Non-admins never see the controls; a 403 is handled with a message, not a blank
FR-4.7	Record payment handoff: opens the income form with the member pre-selected and the last-used fee type suggested	M	One click from Member 360 or the list row
FR-4.8	Printable member statement with letterhead (period selectable)	S (P2)	Same numbers as the Statement tab; prints in the UI language
FR-4.9	Attendance history per member	C (P3)	Needs <code>GET /members/:id/attendance</code>

FR-5 · Incomes and expenses (the ledger)

ID	Requirement	Pri	Acceptance criteria
FR-5.1	Ledger list with filters — search, type, date presets (this month / last month / this year / custom) — kept in the URL; pagination 25 / 50 / 100; total for the active filter	M	Same result set as the desktop for the same filter; totals match
FR-5.2	Adaptive income form by type code: member-required codes, one-time fee guard, fine reason, funeral food / bank interest / building / asset sources, "other" requires a description, guest payer for non-members, notes	M	Field set per code identical to the desktop; server errors (one-time fee already paid, loan-generated entries) surface verbatim
FR-5.3	Adaptive expense form: member-benefit codes prefill the standard payout from settings, bill categories + payee, voucher number, insufficient-funds pre-check against the selected wallet	M	Payout defaults equal settings; the pre-check message matches the server's
FR-5.4	Void with mandatory reason; delete allowed only for voided entries; loan-generated entries are read-only	M	Voided rows are visibly struck through and excluded from totals
FR-5.5	Receipt (income) and voucher (expense) printing with the existing numbering (<code>INC-00001</code> , <code>EXP-</code> /voucher number) and templates, one click from the row and from the success toast	M	Byte-identical numbering; the printed page matches the desktop template in both languages
FR-5.6	Receipt / voucher preview drawer before printing	S (P2)	Enter prints; the preview uses the print stylesheet
FR-5.7	CSV export of the whole filtered set with a UTF-8 BOM and headers in the UI language	M	Opens in Excel with Sinhala intact; row count equals the filter total
FR-5.8	Member picker everywhere matches name, member ID or NIC and shows <code>ID · NIC</code> under the name	M	Same semantics as <code>utils/members.ts</code>

FR-6 · Loans

ID	Requirement	Pri	Acceptance criteria
FR-6.1	Portfolio sorted by member ID by default (natural order, newest first on ties), sortable by balance, principal and date; search by name, NIC, member ID or purpose; exposure total; status pills (Active, Overdue, Paid, Defaulted, Migrated)	M	Order equals desktop 1.3.6+; pills translated
FR-6.2	Issue loan: borrower picker; existing-loans panel for the borrower (open loans, outstanding, headroom); exactly two distinct guarantors, neither the borrower; headroom rule = <code>max_loan_limit - outstanding principal</code> across Active/Overdue loans (<code>max_loan_limit = 0</code> disables the cap); guarantor cap counts distinct borrowers; wallet balance check; amount input capped at headroom	M	Every rule message equals the server's (<code>validateLoanRules</code>); a member with Rs 20,000 open on a Rs 100,000 limit can borrow $\leq$ Rs 80,000; headroom shown with thousands separators
FR-6.3	Migration-mode kind chooser (new vs existing) and migrate existing loan: original/remaining principal, interest and fines owed, issue date, "balances as of" date, next-charge preview (month-end clamped), optional guarantors, Defaulted flag; no cap applies	M	Preview equals the server's first accrual; entry creates no wallet movement
FR-6.4	Repay: waterfall preview fines $\rightarrow$ interest $\rightarrow$ principal, amount $\leq$ total owed, receiving wallet must be active; receipt LNP- printed from the success toast	M	Allocation shown equals the server's <code>allocation</code> response; "Paid" celebrates with the settled animation
FR-6.5	Loan detail page (<code>/loans/:id</code>): balances, guarantors with links, payment history, accrual dates, repay action, statement print (<code>LN-</code>)	M	Payment list equals <code>/loans/:id/payments</code>
FR-6.6	Delete loan with consequence text (normal vs migrated) and typed confirmation	M	Reversal behaviour unchanged (server)
FR-6.7	Accrual on read (<code>GET /loans</code>) is respected: portfolio refetch is throttled (60 s stale, no refetch on window focus)	M	No duplicate accrual observable in the ledger
FR-6.8	Loan requests from the mobile app are visible under Messages $\rightarrow$ Requests with a hint linking to Issue loan	M	Same as desktop

FR-7 · Wallet hub (wallets, transfers, fixed deposits, assets)

ID	Requirement	Pri	Acceptance criteria
FR-7.1	Wallet list with balances, type pills, active toggle; add wallet (opening balance only in migration mode); deposit (migration mode only); delete rules as server	M	Every gating condition mirrors the server response — no error-toast-only paths
FR-7.2	Transfer between wallets with balance pre-check and confirmation	M	Both balances update in the same render

ID	Requirement	Pri	Acceptance criteria
FR-7.3	Fixed deposits: create (fund-from-wallet hidden in migration mode), edit, withdraw (linked / unlinked messages), maturing ≤ 30 days highlighted, computed "Matured" display status	M	Highlight set equals the dashboard attention count
FR-7.4	Society assets: list, add, edit, delete with sources list	M	Actions present (the desktop audit found them missing once)
FR-7.5	Hub tabs in the URL: <code>?tab=liquid investments assets</code>	M	Deep-linkable

FR-8 · Reports

ID	Requirement	Pri	Acceptance criteria
FR-8.1	Monthly report (income/expense by type, net, opening/closing) with month picker	M	Totals equal the ledger for the same month
FR-8.2	Annual report with the position table	M	Equal to desktop
FR-8.3	Arrears report: overdue loans, FDs maturing, members with unpaid fees (note when in migration mode) with sub-tabs	M	Deep links from the dashboard land on the right sub-tab
FR-8.4	Print with society letterhead (name, address, generated date, period), no application chrome, ruled tables, Sinhala titles	M	Printed A4 has no cut tables; header repeats on each page
FR-8.5	CSV export per report	S	BOM, localized headers
FR-8.6	Saved report presets	C (P3)	—

FR-9 · Messages (announcements, member requests, Puruka administration)

ID	Requirement	Pri	Acceptance criteria
FR-9.1	Announcements: create death / meeting / general notices (member picker for the deceased), edit, hide/show, delete; push side-effects unchanged (server)	M	Same payloads as the desktop; hidden notices disappear from the mobile app
FR-9.2	Member requests: pending / all, approve or reject with a staff note, loan-request hint linking to Issue loan	M	Status pills translated; the member sees the note in the app
FR-9.3	Puruka administration: listing filters, reported-only view, take down / restore, categories (code / English / Sinhala)	M	Same endpoints (/puruka-admin)
FR-9.4	Tabs in the URL: <code>?tab=announcements requests puruka</code>	M	Deep-linkable

FR-10 · Attendance

ID	Requirement	Pri	Acceptance criteria
FR-10.1	Events: create (type, title, date, attendance mode present/absent), edit, delete, list with counts	M	<code>attendance_mode</code> semantics as in migration 013
FR-10.2	Marking screen: scanner / typed society ID with OK / duplicate / unknown feedback (colour, motion, sound optional) and automatic refocus; mark from the list; undo; search; present/absent tabs	M	Scanner burst of 5 reads in 2 s produces 5 marks; counts equal the server's <code>attendee_count</code>
FR-10.3	Switching mode asks for confirmation and clears marks (server transaction)	M	Same as desktop 1.3.4
FR-10.4	"Scan anywhere" keyboard-wedge sink: a fast burst ending in Enter, when no field is focused, opens the member or marks attendance on the attendance screen	S (P2)	Heuristic (≥ 6 chars within 250 ms) confirmed with the pilot office's scanner
FR-10.5	Offline-tolerant attendance queue for meeting halls with poor connectivity	C (P3)	—

FR-11 · Settings and users

ID	Requirement	Pri	Acceptance criteria
FR-11.1	Tabs — General, Loan engine, Income types, Expense types, System users, About — in the URL	M	Same fields as desktop; max loan limit entered in rupees, stored in cents
FR-11.2	Income / expense types: system types renameable but not deletable, deactivate / reactivate	M	Same rules
FR-11.3	System users (<code>admin</code> only): create with role <code>admin</code> / <code>user</code> / <code>viewer</code> , delete (never self or the last admin), reset password	M	Last-admin message shown; non-admins see the notice card
FR-11.4	About: web and API versions, samithi name + code, "Change samithi" (forgets the remembered code), export settings JSON	M	—
FR-11.5	Security section: change password, sessions list	M / S	See FR-1.6, FR-1.7

FR-12 · Printing and exports

ID	Requirement	Pri	Acceptance criteria
FR-12.1	Receipt, voucher, loan receipt and statement templates ported from <code>utils/print.ts</code> with identical numbering	M	Unit snapshot tests in both languages; side-by-side print comparison with desktop 1.3.7 in the sign-off
FR-12.2	Printing renders in a sandboxed iframe with a dedicated print stylesheet, always in the light theme, A4 and 80 mm-friendly receipt widths	M	Dark mode never leaks into paper
FR-12.3	Report letterhead (society name, address, phone, generated timestamp, period)	M	—

ID	Requirement	Pri	Acceptance criteria
FR-12.4	CSV rules: UTF-8 BOM, RFC 4180 escaping, dates YYYY-MM-DD, amounts as numbers, headers in the UI language	M	Round-trips through Excel and LibreOffice

FR-13 · Localisation (Sinhala / English)

ID	Requirement	Pri	Acceptance criteria
FR-13.1	Every string in both languages, including everything the desktop left in English: offline bar, session toast, discard dialog, a11y labels, "Rows per page", enum badges (transaction, loan, wallet, FD, asset, request status), CSV headers, placeholders, and the building / asset / bill option lists (display translated, canonical English stored in <code>notes</code> for parity)	M	CI <code>check:i18n</code> fails on any missing key or placeholder mismatch; a screenshot sweep in Sinhala shows no Latin UI text except numbers, codes and proper nouns
FR-13.2	<code><html lang></code> follows the UI language; Sinhala typography rules apply automatically (§4.3)	M	Axe reports the correct language; no clipped Sinhala glyphs
FR-13.3	Dates and months in Sinhala mode use the existing month names; currency stays <code>Rs. 12,500.00</code>	M	Same as desktop
FR-13.4	Terminology review of financial terms by the pilot treasurer before GA	M	Sign-off item 9

FR-14 · PWA and the desktop shell

ID	Requirement	Pri	Acceptance criteria
FR-14.1	Installable PWA (manifest, icons, standalone display); install offered only from the user menu	M	Lighthouse "installable" passes; no install banner nags
FR-14.2	Service worker precaches the shell only; API and directory calls are never cached; updates prompt "New version — Reload"	M	Kill the network: the shell renders with the offline banner; restore: data loads without reload
FR-14.3	Desktop 1.3.8 thin shell : loads the web URL in a persistent session, offline fallback page, navigation locked to the app origin, external links in the system browser, UA suffix <code>eSamithiShell/1.3.8</code> , silent auto-update retained	M (Phase 5)	Existing 1.3.7 installs update to the shell through the same feed; the refresh cookie survives a restart
FR-14.4	Print from the shell uses the native print dialog	M (Phase 5)	Receipts print as before

FR-15 · Support mode (operator impersonation) — Phase 5

ID	Requirement	Pri	Acceptance criteria
FR-15.1	The console's "Enter samithi" hands off to <code>\${app_url}/support#s=<payload></code> ; the app stores the payload in <code>sessionStorage</code> , strips the fragment and runs in bearer-token mode without refresh	S	Same behaviour as <code>workspace.tsx</code> today, including the percent-decoding fix
FR-15.2	Permanent red banner with actor, society and countdown; Exit revokes on the platform and closes the tab	S	—
FR-15.3	<code>/workspace/</code> stays deployed until the handoff is switched	M	No operator downtime

4. UX redesign specification

4.1 Design principles

- 1. **Counter-first.** The treasurer's collection day is the primary scenario: find, record, print, next — in under ten seconds per member, keyboard and scanner only.
- 2. **Calm professionalism.** Generous whitespace, one accent colour, restrained type scale, no decorative gradients inside the workspace (the brand gradient lives in the login screen, the mark and the empty states).
- 3. **Motion explains, never entertains.** Every animation answers "what just happened?" or "where did that come from?"; two celebratory moments only (loan fully settled, receipt printed).
- 4. **Sinhala is a first-class script**, not a translation layer: line-height, weight and size rules are built into the type system.
- 5. **Nothing destructive without a second look.** Money and member actions confirm with consequence text; deletions need a typed confirmation.
- 6. **The URL is the state.** Anything a user can see can be shared, bookmarked and returned to with the browser's back button.
- 7. **Works on the hardware the villages have.** Older Windows laptops, 1366×768 screens, USB keyboard-wedge scanners, inkjet printers, intermittent 4G.

4.2 Visual identity and colour tokens

Tokens are CSS custom properties consumed by Tailwind v4 `@theme` . Light and dark palettes switch on `[data-theme]` with the same attribute and `localStorage` keys the desktop uses (`esamithi-theme` , `esamithi-lang` , `esamithi-sidebar-collapsed`).

Brand blue scale (600 is the brand, 700 the hover, 400 the dark-mode primary)

Step	50	100	200	300	400	500	600	700	800	900	950
Hex	#EEF4FE	#D8E6FC	#B3CDF8	#85B0F2	#4C8DF6	#2E75E3	#1E64D4	#1854B8	#164699	#143B7C	#0F2650

Navy / slate neutrals

Step	50	100	200	300	400	500	600	700	800	900	950
Hex	#F8FAFC	#F1F5F9	#E2E8F0	#CBD5E1	#94A3B8	#64748B	#475569	#334155	#1E293B	#0F172A	#0B1120

Semantic tokens (light / dark)

Token	Light	Dark	Use
<code>--color-bg</code>	#F5F7FA	#0B1220	Page background
<code>--color-surface</code>	FFFFFF	#111A2B	Cards, tables, sheets
<code>--color-surface-elevated</code>	FFFFFF	#17223A	Dialogs, popovers
<code>--color-border</code>	#E5E7EB	#243046	Hairlines
<code>--color-text</code>	#0F172A	#E2E8F0	Body text
<code>--color-text-muted</code>	#475569	#94A3B8	Secondary text
<code>--color-text-subtle</code>	#94A3B8	#64748B	Placeholders, hints

Token	Light	Dark	Use
<code>--color-primary</code>	blue-600	blue-400	Actions, links, focus
<code>--color-sidebar</code>	#0F172A	#0B111B	Sidebar background
<code>--color-success</code>	#16A34A	#22C55E	Income, paid, OK
<code>--color-warning</code>	#D97706	#FBBF24	Maturing, pending
<code>--color-danger</code>	#DC2626	#EF4444	Expense, overdue, destructive
<code>--color-info</code>	blue-500	blue-300	Neutral notices

Each semantic colour has a `--soft` background (tint in light, 12 % alpha in dark). Income is always success-coloured and expense danger-coloured **with** a sign or icon, so colour is never the only carrier of meaning. Chart palette (categorical): #1E64D4 #16A34A #8B5CF6 #D97706 #0EA5E9 #E11D48 (dark: #4C8DF6 #22C55E #A78BFA #FBBF24 #38BDF8 #FB7185), grid #EEF1F5 / #263043 . Brand gradient `linear-gradient(135deg, #3B82F6 0%, #1E64D4 100%)` ; mark = squircle with 24 % corner radius and a white "eS" in Inter 800 at -0.02 em.

4.3 Typography

Rule	Latin (<code>lang=en</code>)	Sinhala (<code>lang=si</code>)
Family	Inter (variable, self-hosted woff2)	Noto Sans Sinhala 400 / 600 / 700 (self-hosted, unsubsetted) with Inter for digits and Latin
Body size / line-height	14 px / 1.5	15 px / 1.65
Headings line-height	1.2	1.4
Letter-spacing	headings may use -0.01 em	always 0
Max weight	800 (brand mark only)	700 (Noto has no 800)
Scale	11 · 12 · 13 · 14 · 16 · 18 · 20 · 24 · 30 px	same, applied to the 15 px base
Numbers	<code>font-variant-numeric: tabular-nums</code> in every money and numeric cell (<code>.tnum</code>)	Latin numerals always (matches receipts today)
Currency	Rs. 12,500.00 (<code>en-LK</code>)	same

`<html lang>` is set by the i18n provider, so the `:lang(si)` rules apply automatically to every component.

4.4 Spacing, radii, elevation, focus

- 4-pt spacing grid; page gutter 24 px (16 px < 1024); card padding 20 px; table cell 10 × 12 px.
- Radii: 6 inputs · 8 buttons · 12 cards · 16 dialogs and sheets · 999 pills.
- Elevation: `sm 0 1px 2px rgba(0,0,0,.05)` · `md 0 4px 6px -1px rgba(0,0,0,.07)` · `lg 0 10px 15px -3px rgba(0,0,0,.08)` · `modal 0 20px 60px rgba(0,0,0,.15)` ; dark mode multiplies alpha × 6.
- Focus ring `0 0 0 3px rgba(30,100,212,.25)` on every interactive element, visible for keyboard users only (`:focus-visible`).

4.5 Motion system

Token	Value	Used for
<code>--dur-instant</code>	80 ms	Hover, press
<code>--dur-fast</code>	150 ms	Toggles, tooltips, tab indicator
<code>--dur-base</code>	220 ms	Dialog, sheet, toast
<code>--dur-slow</code>	320 ms	Page transitions, drawer
Stagger	30 ms per item, max 8 items, first mount only	Lists, KPI grid
Easings	standard <code>cubic-bezier(.2,0,0,1) · enter cubic-bezier(0,0,0,1) · exit cubic-bezier(.3,0,1,1) · spring {stiffness 400, damping 30}</code> (delight only)	

Patterns: dialog fade + scale .96 → 1; sheet slides from the right; toast slides from bottom-right; page fade + 4 px rise; list stagger on first data; KPI count-up once per session; row flash after a mutation; button pending state (spinner replaces label, width preserved); scanner hit / duplicate / miss pulse in green / amber / red; check-mark draw when a loan is fully settled or a receipt is printed. `MotionConfig` `reducedMotion="user"` and `prefers-reduced-motion` zero every duration and transform.

4.6 Component inventory

All primitives are generated by shadcn/ui into `web/src/components/ui` (owned code, restyled with tokens). Product components sit in `web/src/components`.

Component	Notes
Button	primary / secondary / ghost / destructive / link; sm / md / lg / icon; <code>loading</code> state
Input, Textarea, Checkbox, Switch, Select (Radix, short enums)	Inline error text and description slots
Combobox (cmdk) → MemberPicker	Searches <code>/members/slim</code> by name, member ID, NIC; sublabel <code>ID · NIC</code> ; recent picks; keyboard-first; scanner-friendly
RupeelInput	Port of the desktop rules: emits cents, thousands separators while typing, <code>max</code> , no negatives
DatePicker + DateRangePicker	Styled native date inputs for reliability; presets from <code>LedgerFilterBar</code> ; parses only the leading <code>YYYY-MM-DD</code> so a date never shifts a day
DataTable (TanStack Table)	Sort, filter, column visibility, sticky header, client or server pagination, virtualised > 200 rows, row actions, loading and empty states
Dialog, Sheet, Drawer (vaul on phones)	Forms open in a Sheet on desktop and full page on phones
ConfirmDialog	Danger variant, consequence text, typed confirmation for loan and member deletion
Toast (sonner)	3 s success / 6 s error, de-duplicated by message, action slot ("Print receipt")

Component	Notes
Tabs, Badge → StatusPill	Every enum maps to an i18n label and a semantic colour
EmptyState, Skeleton (table / card / KPI)	Every list has a designed empty and loading state
StatCard / StatGrid, chart wrappers	recharts reading CSS variables; optional sparkline and delta
CommandPalette	Ctrl/⌘ K: member search, navigation, quick actions
PrintPreview	Sheet with a sandboxed iframe rendering the receipt HTML; Enter prints
BannerStack	migration / offline / update / maintenance / support
SessionDialog	Re-authenticate in place; retries the failed request
Tooltip, DropdownMenu, Avatar, Kbd, ScrollArea, Separator, Pagination, Form primitives (react-hook-form + Zod), LangSwitcher, ThemeToggle, NumberTicker	

4.7 Application shell and page templates

- **Shell:** sidebar 260 px (collapsed 72 px), top bar 56 px, banners under the top bar, breadcrumbs on detail routes, footer with versions. Sidebar groups: Money (Dashboard, Incomes, Expenses, Loans, Wallet) · People (Members, Attendance) · Society (Messages, Reports) · System (Settings).
- **List template:** page header + primary action → filter bar (URL-bound) → DataTable → pagination footer with total.
- **Detail template:** identity header (name, IDs, status pill, actions) → tabs → optional side panel with quick facts.
- **Form template:** Sheet on desktop (560 px), full page on phones; Zod schema per form; inline validation on blur, summary on submit; primary action pinned to the footer.
- **Report template:** period picker → printable area with letterhead → Print / CSV actions.
- **Login:** split layout — brand panel (gradient, mark, tagline in both languages, illustration) and a card with the two steps (samithi code → credentials), language switch and a maintenance notice slot.

4.8 Route map and URL state

Route	Content	URL state
/login	Samithi code → credentials	?code=
/dashboard	KPIs, attention, chart, activity	—
/members, /members/:id	List; Member 360	?q&status&page&sort; ?tab=overview statement loans dependents access
/incomes, /expenses	Ledgers	?q&type&from&to&preset&page&size
/loans, /loans/:id	Portfolio; detail	?q&sort&dir&status; ?tab=
/wallet	Hub	?tab=liquid investments assets

Route	Content	URL state
/reports	Reports	? tab=monthly annual arrears&year&month&arrears=overdue fds members
/messages	Notices, requests, Puruka	?tab=announcements requests puruka&status
/attendance, /attendance/:eventId	Events; marking	?tab=present absent&q
/settings	Settings	?tab=general loans income expense users about security
/support	Operator support mode	#s= (consumed once)

4.9 Interaction patterns

- **Forms:** validate on blur, block submit with a summary, keep focus order logical, never clear a form on a failed submit, preserve drafts through session re-authentication.
- **Confirmations:** destructive money/member actions use ConfirmDialog with consequence text; loan and member deletion require typing an identifier.
- **Feedback:** every mutation shows a pending state on its button, a toast on completion (with a print action where relevant) and a row flash in the list.
- **Errors:** API {error} messages surface verbatim (they are already user-facing and localised where the server knows the language); network errors show the offline banner with Retry; unknown errors show the recovery card and are reported to /client-errors.
- **Keyboard and scanner:** / search, N new, Esc close, Enter prints in previews; scanner bursts are recognised by timing and end with Enter; the input keeps focus after each read.
- **Loading:** skeletons for first load, subtle top progress bar for background refetches, never a blocking spinner over a whole page.
- **Empty states:** every list explains what would appear and offers the primary action.

4.10 UX upgrades beyond desktop parity

Priority	Upgrade
P1 (v1.0)	Deep-link routes instead of modal-only flows · Member 360 page · Loan detail page · Command palette · URL-persisted filters · Responsive shell (tablet ≥ 768) · In-place session re-authentication · StatusPill translating every enum · Counter keyboard shortcuts · Dates that never shift a day
P2 (v1.0 if time allows, else v1.1)	Receipt / voucher preview drawer · Scan-anywhere sink · Sessions + sign-out everywhere · Change password UI · viewer role selectable in Users · Printable member statement · 12-month dashboard trends · Install-app menu item · Print always in light theme
P3 (later)	Attendance history per member · Saved report presets · Bulk membership-fee posting · Offline-tolerant attendance queue · Server-side PDF · Console restyle on the same tokens

4.11 Accessibility

WCAG 2.2 AA as the bar: contrast ≥ 4.5:1 for text (tokens verified in both themes), visible focus, full keyboard operation, focus traps in dialogs and sheets, aria-live for toasts and scanner feedback, labelled icon buttons, table headers with scope, reduced-motion support, minimum target size 32 px (44

px on touch), and `lang` attributes for screen readers. Axe runs on every route in CI; serious or critical violations fail the build.

4.12 Dark mode and print

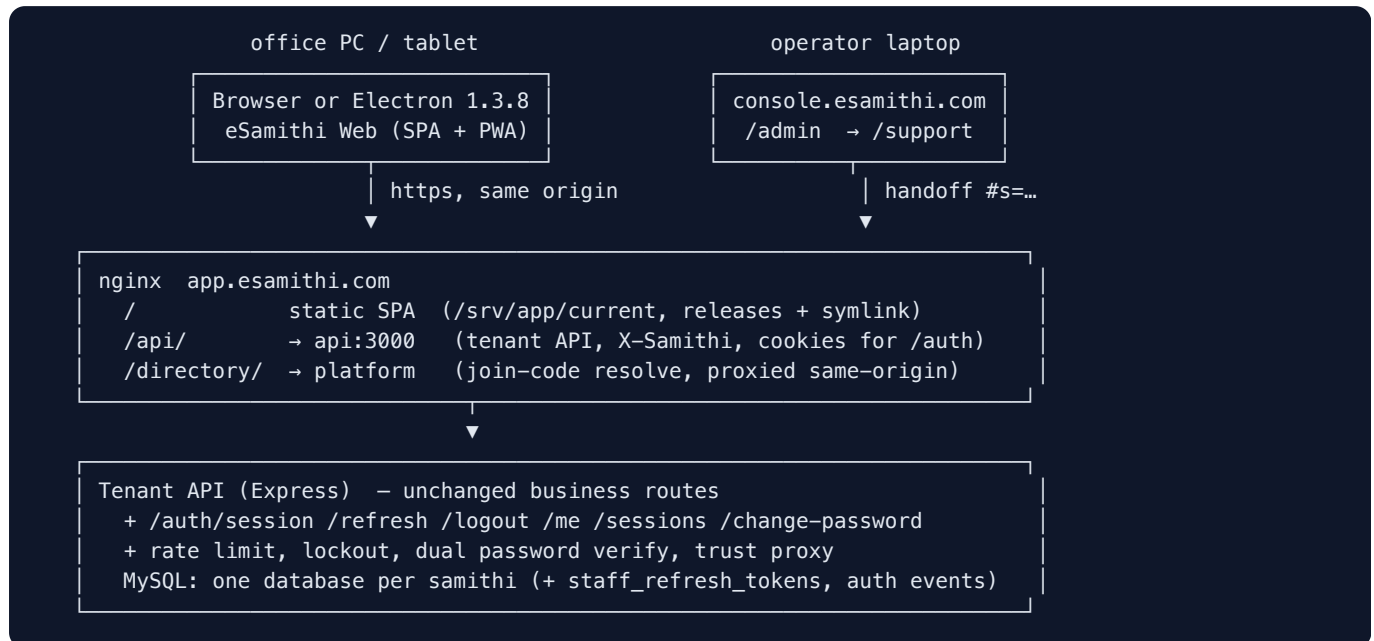
Dark mode is a complete token set, not an inversion; charts, pills and banners have dark variants. Printing always uses the light theme through the print stylesheet, hides all chrome, repeats table headers, avoids page breaks inside rows, and sets `@page` margins for A4 (reports, statements) and narrow receipts.

5. Non-functional requirements

Area	Requirement	Verification
Performance	LCP < 2.5 s and TBT < 200 ms on a mid-range laptop over throttled 4G; CLS < 0.1; initial JS ≤ 250 KB gzip (route-level code splitting; recharts, print, reports and Puruka lazy); fonts ≤ 350 KB total; member search response rendered ≤ 300 ms after typing on the testbed	Lighthouse CI budgets on every main build; Playwright timing assertions
Availability	The web app is static; its availability equals the API's. Health monitored (/ and /api/v1/health) by Uptime Kuma and health-alert.sh	Monitors added in Phase 4
Compatibility	Last two versions of Chrome and Edge (recommended for offices), Firefox, Safari 17+; Android Chrome on tablets; 1366×768 and up fully supported, 1024 px minimum for the full layout	Playwright projects: Chromium, Firefox, WebKit; manual pass on the pilot office PC
Security	See §7: HttpOnly refresh cookie, 15-minute access tokens, rotation and reuse detection, logout, rate limits, strict CSP, HSTS, no secrets in storage, no third-party scripts	Automated auth tests, header checks in the smoke script, dependency audit in CI
Privacy	No analytics or third-party requests; error reports contain no personal data beyond the user id and route	Code review; CSP connect-src 'self' enforces it
Localisation	100 % string coverage in English and Sinhala; CI parity check	check:i18n
Accessibility	WCAG 2.2 AA (see §4.11)	axe in CI, manual keyboard pass
Reliability of money entry	No optimistic UI for money mutations; double-submit protection on every form; idempotent retry after re-authentication only for GET requests, mutations are re-confirmed	Component tests, E2E
Observability	Client errors reported to /client-errors with app version and route; nginx access logs carry the shell UA for adoption tracking	Log review in the pilot
Maintainability	TypeScript strict; ESLint; owned UI primitives; feature-folder structure; unit + component + E2E tests; ADR-style notes in web/docs/	CI gates
Data safety	No data migration; additive schema only; every production deploy preceded by backup.sh ; rollback tested on the testbed first	§11 protocol
Capacity	Comfortable for societies up to 5,000 members and 100,000 ledger rows with server pagination; the live society has ≈ 150 members	Load test on the testbed with a synthetic 5,000-member tenant (Phase 3)

6. Architecture

6.1 Overview



Desktop 1.3.7 keeps calling the same API with `POST /auth/login` and its 24-hour bearer token; the mobile app keeps calling `/member-auth` and `/me`. Neither sees any change.

6.2 Repository structure

`web/` is a new, independent package tree (same convention as `mobile/` and `platform/`; the repository does not become an npm workspace). Nothing under `src/` is imported by `web/`, so web work can never break the frozen desktop.

```

web/
package.json      dev · build · build:testbed · preview · typecheck · lint · test · test:e2e ·
                  sync:i18n · check:i18n · fonts:build
vite.config.ts    base from VITE_BASE ('/' prod, '/app/' testbed); __APP_VERSION__; dev proxy
                  /api + /directory → https://console.esamithi.com; vite-plugin-pwa
components.json   shadcn configuration
index.html        public/{offline.html, icons/*, robots.txt}
scripts/
  sync-i18n.mjs    src/renderer/src/i18n/{en,si}.ts → src/lib/i18n/generated/{en,si}.json +
keys.d.ts         check-i18n.mjs    CI: en/si key sets identical, every t('...') literal exists, {placeholders}
match
  build-fonts.sh   TTF (mobile/assets/fonts) → woff2 (committed artifacts)
src/
  main.tsx
  app/router.tsx   app/providers.tsx    Query · Theme · I18n · Auth · MotionConfig · Toaster
  app/routes/      TanStack Router file routes (§4.8)
  app/shell/        AppShell, Sidebar, TopBar, BannerStack, CommandPalette,
                  SessionDialog, ScanSink
  features/<module>/
                  api.ts (typed endpoints + query keys) · queries.ts (hooks +
                  invalidation) · schemas.ts (zod) · components/ · utils.ts ·
__tests__/
  auth dashboard members ledger loans wallet reports attendance messages settings support
  components/ui/    shadcn primitives (owned code)
  components/       RupeeInput, MemberPicker, DataTable, StatusPill, EmptyState,
                  StatCard, DateRangePicker, PrintPreview, PageHeader,
FilterBar, charts/
  lib/api/          client.ts · session.ts · samithi.ts (directory + host map) ·
                  errors.ts · types.ts (DTOs ported from
src/renderer/src/types)
  lib/i18n/         provider, generated/{en,si}.json, extra/{en,si}.json (web-
only keys)
  lib/print/        receipt.ts (buildReceiptHtml, ported verbatim) · numbers.ts
· print.css
  lib/format/       currency.ts · dates.ts · csv.ts
  lib/constants/    banks.ts · incomeCodes.ts · expenseCodes.ts · sources.ts
  lib/motion.ts     lib/scanner.ts lib/pwa.ts lib/migrationMode.ts
  styles/tokens.css · globals.css · print.css
  assets/fonts/*.woff2 assets/brand/
  test/            vitest setup, msw/handlers.ts, msw/data.ts
e2e/               Playwright specs, fixtures/testbed.ts, fixtures/mock.ts
docs/             ADR notes, parity sign-off log

```

Ported with tests (one-time port or generated by script): i18n dictionaries (≈ 890 keys per language; the desktop stays the source of truth until it is frozen, then the generated JSON becomes the source), fonts, `utils/formatters.ts`, `utils/print.ts` (receipt builder and numbering — must stay byte-identical), `constants/banks.ts`, `utils/members.ts` picker semantics, the adaptive-form code tables and option constants from the income/expense modals, `LedgerFilterBar` presets, `types/index.ts` as DTOs, theme and language storage keys.

Deliberately not shared: `App.css`, every page, modal and hook, `workspace/shim.ts`, Electron main/preload, `src/admin`, mobile.

6.3 Stack and rationale

Choice	Why
React 19 + TypeScript + Vite 6	Same language and build tool as the current renderer; fastest path for the team

Choice	Why
TanStack Router	Typed search params make ledger filters and deep links first-class; loaders integrate with TanStack Query
TanStack Query	Already used in <code>mobile/</code> ; explicit cache keys and invalidation replace the desktop's ad-hoc <code>invalidateCaches</code>
TanStack Table (+ react-virtual for the un-paginated loan list)	Headless; the shadcn DataTable recipe builds on it
Tailwind v4 + shadcn/ui (Radix)	Design tokens as CSS variables; accessible primitives as owned code, restyled freely
Motion	Declarative, interruptible animations; <code>reducedMotion="user"</code>
react-hook-form + Zod	One schema per form, shared between validation and tests
sonner, cmdk, vaul	Toasts, command palette, phone drawer — small, accessible, well maintained
recharts	Already used; shadcn chart wrappers are recharts-based
vite-plugin-pwa	Prompt-mode updates, precache of the shell only
Vitest + Testing Library + MSW; Playwright + <code>@axe-core/playwright</code> ; Lighthouse CI	Unit, component, E2E, accessibility and performance gates

6.4 Same-origin topology and multi-server routing

Rule: the SPA only ever calls `${location.origin}/api/v1` and `${location.origin}/directory/`; the `X-Samithi` header selects the tenant. This is the support workspace's mixed-content workaround made the only path, and it is what lets the refresh cookie exist.

- **Production:** new vhost `deploy/prod/nginx/app.conf.disabled` (clone of `api.conf.disabled`):
`resolver 127.0.0.11`, variable `proxy_pass`, `/api/` → `http://api:3000`, `/directory/` → platform proxy, `client_max_body_size 50m`, `/` → `/srv/app/current` with `try_files $uri /index.html`.
Releases live in `/opt/esamithi-stack/app/releases/<version>` with a **relative** `current` symlink (resolves inside the container; rollback = symlink flip). `enable-app-tls.sh` issues the certificate into the existing certbot volume and **must not reinstall the renew cron** (`certbot renew` already covers every lineage).
- **QA host:** `https://console.esamithi.com/app/` (`VITE_BASE=/app/`, `console.conf` gains `/app/` locations, compose mounts `./app`). CI deploys `web/dist` there on every push to `main` touching `web/**`.
- **Caching:** `/assets/` immutable (one year), `index.html`, `sw.js` and the manifest `no-cache` — the lesson from the July workspace incident.
- **Cross-server login:** join code → resolve → compare the API origin of `api_url` with this build's `VITE_API_ORIGINS`; on mismatch redirect to `${app_url}/?code=XXX`. `app_url` is an additive `servers.app_url` column on the platform surfaced in the resolve response; until it lands, a build-time host map is the fallback (`https://api.esamithi.com/api/v1` → `https://app.esamithi.com`, `http://212.227.103.150/api/v1` → `https://console.esamithi.com/app/`). `min_app_version` is ignored by the web (it self-updates).
- **Security headers** (nginx include on every static location — `add_header` in a `location` discards inherited headers): HSTS `max-age=31536000`; `includeSubDomains`; CSP `default-src 'self'`; `script-src 'self'`; `style-src 'self' 'unsafe-inline'`; `img-src 'self' data: blob;`; `font-src`

'self'; connect-src 'self'; manifest-src 'self'; worker-src 'self'; frame-ancestors 'none'; base-uri 'self'; form-action 'self'; object-src 'none'; upgrade-insecure-requests ('unsafe-inline' for styles only — Motion, recharts, Radix and the receipt HTML need inline styles; scripts stay strict); X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: camera=(), microphone=(), geolocation=(); X-Frame-Options: DENY; gzip for text assets.

- **Private preview gate:** `auth_basic` on `location /` only (never on `/api/`), service worker disabled in the RC build (`VITE_PWA=off`), removed at GA.

6.5 Authentication and session protocol

Transport. Refresh token: `Set-Cookie: __Secure-es_rt=<slug>.<64-hex>; HttpOnly; Secure; SameSite=Strict; Path=/api/v1/auth; Max-Age=43200` (`es_rt` without prefix on plain-HTTP dev). Path-scoped so it only travels to `/api/v1/auth/*`; the `<slug>` prefix lets the server reject a cookie presented under the wrong `X-Samithi`. Access token: JWT, 15 minutes, held only in a module variable — never in web storage. On reload the SPA calls `POST /auth/refresh` first, then `GET /auth/me`.

Defence in depth on `/auth/refresh` and `/auth/logout`: header `X-Requested-With: eSamithi` required (forces a CORS pre-flight for any cross-origin attempt), `Sec-Fetch-Site: cross-site` rejected, and `X-Samithi` must equal the slug embedded in the cookie.

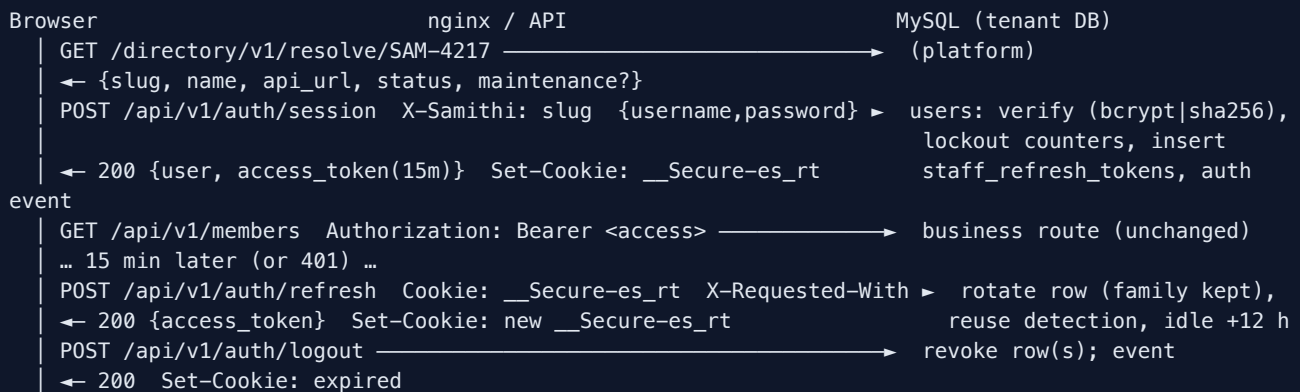
Endpoints (all additive; `POST /auth/login` byte-for-byte unchanged)

Endpoint	Purpose	Response
<code>POST /api/v1/auth/session</code>	Web login ({username, password} + <code>X-Samithi</code>)	{success, user:{id, username, full_name, role}, access_token, expires_in: 900} + refresh cookie
<code>POST /api/v1/auth/refresh</code>	Rotate; cookie in, new cookie out	{access_token, expires_in}
<code>POST /api/v1/auth/logout (?all=1)</code>	Revoke the presented session (or every session of the user)	{success} + expired cookie
<code>GET /api/v1/auth/me</code>	Fresh user row, tenant and session info (works for impersonation tokens too)	{id, username, full_name, role, samithi:{slug,name}, session:{id, expires_at, absolute_expires_at, client} null, support:{actor, sid, expires_at} null}
<code>GET /api/v1/auth/sessions</code> · <code>DELETE /api/v1/auth/sessions/:id</code>	Own sessions list and revoke	id, client, ip, user_agent, created_at, last_used_at, current
<code>POST /api/v1/auth/change-password</code>	Self-service ({current_password, new_password})	{success}; revokes other sessions
<code>PATCH /api/v1/users/:id/password</code>	Admin reset (existing requireAdmin router)	{success}; revokes that user's sessions

A separate `/auth/session` endpoint (rather than a flag on `/auth/login`) keeps zero risk to the desktop contract and lets the two be rate-limited and locked out independently.

Token contents. The access JWT mirrors the legacy claims so `middleware/auth.js` needs no change: `{ id, username, role, sam, typ: 'access', sid: <session family id>, exp: +15 min }`, signed with the same `JWT_SECRET`. The `sam` check and the `viewer` read-only guard keep working unchanged.

Sequence



Semantics

- **Rotation:** each refresh marks the presented row `revoked_at = NOW()`, `revoke_reason = 'rotated'`, `replaced_by = <new id>` and inserts a successor in the same `family_id` with `expires_at = NOW() + 12 h`; `absolute_expires_at` (sign-in + 24 h) is copied, forcing a daily sign-in.
- **Reuse detection:** a presented token with `revoked_at IS NOT NULL` → if it was rotated < 5 s ago and `replaced_by IS NOT NULL`, answer 401 `{error: 'Session refreshed elsewhere'}` without punishment (a legitimate two-tab race); otherwise revoke **every** active row of that user (`revoke_reason = 'reuse'`), log `refresh_reuse`, return 401. The SPA prevents the race anyway with `navigator.locks.request('esamithi-refresh')` (cross-tab single flight).
- **Revocation triggers:** change-password, admin reset, console `internal/users/:id/reset-password`, `is_active = 0` (console disable), `DELETE /users/:id` (cascade), `logout?all=1`. Refresh re-checks `is_active` and `created_at > password_changed_at`. Access tokens are not revocable mid-life; 15 minutes is the accepted window (same stance as the platform).
- **Client behaviour:** attach `Authorization + X-Samithi`; on 401 → single-flight refresh → retry once → else the `SessionDialog`. Proactive refresh at 13 min only if the user was active in the last 5 min. `BroadcastChannel('esamithi-auth')` fans out logout to other tabs. The samithi context `{code, slug, name}` lives in `localStorage['esamithi.web.samithi']` (non-secret).

Rate limiting and lockout (invisible to legitimate desktop users)

- `app.set('trust proxy', 1)` — nginx sets `X-Forwarded-For`; this also fixes the member-PIN limiter that currently shares one bucket per tenant.
- `staffLoginLimiter`: key `${ip}|${tenant}`, 15-minute window, 30 attempts, `skipSuccessfulRequests: true`, JSON `{error}` body — applied to both `/auth/login` and `/auth/session`. `refreshLimiter`: 120 / 15 min on `/auth/refresh`.
- Account lockout: 10 failures → `locked_until = NOW() + 15 min`, 423 `{error, locked_until}`; success resets. `STAFF_LOCKOUT_SCOPE=web` (default) applies it to `/auth/session` only; flipped to `all` at cut-over when the desktop is frozen. The failure message stays generic on both endpoints.

Opportunistic bcrypt re-hash — two deploys

1. **Deploy A (fully reversible):** `server/lib/passwords.js` with `verify(plain, stored) = bcrypt` if `stored` starts with `$2`, else `sha256(plain) === stored; hash()` still SHA-256. All five hashing sites import it. No row changes, so rollback to the previous build is safe.
2. **Deploy B (after A has soaked through the pilot):** `PASSWORD_REHASH=on` → on a successful login with a legacy hash, `UPDATE users SET password = bcrypt(plain, cost 10); hash()` becomes `bcrypt` for new and reset passwords (`ci-e2e.sh` seeds through the Node helper instead of SQL `SHA2`). Cost 10 is deliberate for the 1-core ARM host (≈ 100 ms). Re-hashing is one-way per row, so **the rollback floor becomes Deploy A** — never roll back past it. `users.password` is `VARCHAR(255)`; no schema change.

CORS and headers. Same-origin cookies need no CORS at all, so the tightening is hygiene: `origin: (o, cb)` allows requests **without** an Origin (Electron main-process axios, React Native, curl, health checks) and origins listed in `CORS_ALLOWED_ORIGINS`; unset env = current behaviour, so the flag is switched on after a week of logging observed Origins on the testbed. `credentials` stays false. Helmet's API headers are left as they are.

6.6 Database changes (additive, guarded, idempotent)

Migration `014_staff_sessions`, appended to `server/migrations/index.js` and guarded through `INFORMATION_SCHEMA` like `004 / 009 / 012`:

```
CREATE TABLE IF NOT EXISTS staff_refresh_tokens (
  id                INT PRIMARY KEY AUTO_INCREMENT,
  user_id           INT          NOT NULL,
  family_id         CHAR(32)     NOT NULL,          -- one sign-in = one family
  token_hash        CHAR(64)     NOT NULL,          -- sha256(raw); raw never stored
  client            VARCHAR(20)  NOT NULL DEFAULT 'web', -- 'web' | 'shell'
  ip                VARCHAR(45)  DEFAULT NULL,
  user_agent        VARCHAR(255) DEFAULT NULL,
  created_at        TIMESTAMP    DEFAULT CURRENT_TIMESTAMP,
  last_used_at      TIMESTAMP    NULL DEFAULT NULL,
  expires_at        TIMESTAMP    NOT NULL,          -- idle: NOW()+12h at each rotation
  absolute_expires_at TIMESTAMP    NOT NULL,        -- sign-in + 24h, copied on rotation
  revoked_at        TIMESTAMP    NULL DEFAULT NULL,
  revoke_reason     VARCHAR(30)  DEFAULT NULL,      --
  rotated|logout|logout_all|reuse|password|disabled|admin|expired
  replaced_by       INT          DEFAULT NULL,
  UNIQUE KEY uq_srt_hash (token_hash),
  KEY idx_srt_user (user_id, revoked_at),
  KEY idx_srt_family (family_id),
  FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

ALTER TABLE users
  ADD COLUMN failed_attempts INT          NOT NULL DEFAULT 0,
  ADD COLUMN locked_until   TIMESTAMP    NULL DEFAULT NULL,
  ADD COLUMN password_changed_at TIMESTAMP NULL DEFAULT NULL,
  ADD COLUMN must_change_password TINYINT NOT NULL DEFAULT 0;
```

Migration `015_staff_auth_events`: `staff_auth_events (id, user_id NULL, username VARCHAR(100), event VARCHAR(30), client, ip, user_agent, created_at)` for `login_ok | login_fail | locked | refresh_reuse | logout | password_change` — the forensic trail behind the Sessions UI and lockout tuning. Both migrations are inert for the desktop and the mobile app, and both are verified on `samithi01` after the Phase 4 deploy.

6.7 API contract

The web app reproduces the 78-method contract that `workspace/shim.ts` maps onto the existing routes. Existing endpoints used unchanged, by module:

Module	Endpoints (all under <code>/api/v1</code>)
Auth	POST <code>/auth/login</code> (desktop only, frozen) · new: <code>/auth/session</code> , <code>/auth/refresh</code> , <code>/auth/logout</code> , <code>/auth/me</code> , <code>/auth/sessions</code> , <code>/auth/change-password</code>
Users	GET/POST <code>/users</code> , DELETE <code>/users/:id</code> · new: PATCH <code>/users/:id/password</code>
Members	GET <code>/members</code> (<code>?search&status&page&limit</code>), GET <code>/members/slim</code> , GET <code>/members/check-unique</code> , GET <code>/members/:id</code> , GET <code>/members/:id/statement</code> , POST <code>/members</code> , PUT <code>/members/:id</code> , PUT <code>/members/:id/app-access</code> , DELETE <code>/members/:id</code>
Ledger	GET/POST <code>/income</code> , PATCH <code>/income/:id/void</code> , DELETE <code>/income/:id</code> ; same for <code>/expenses</code> ; GET/POST/PUT/DELETE <code>/income-types</code> , <code>/expense-types</code>
Loans	GET/POST <code>/loans</code> , POST <code>/loans/migrate</code> , POST <code>/loans/:id/repay</code> , GET <code>/loans/:id</code> , GET <code>/loans/:id/payments</code> , DELETE <code>/loans/:id</code>
Wallet hub	GET/POST/PUT <code>/wallets</code> , PATCH <code>/wallets/:id/toggle</code> , POST <code>/wallets/transfer</code> , POST <code>/wallets/:id/deposit</code> , DELETE <code>/wallets/:id</code> ; GET/POST/PUT <code>/fixed-deposits</code> , PATCH <code>/fixed-deposits/:id/withdraw</code> , DELETE; GET/POST/PUT/DELETE <code>/assets</code>
Dashboard & reports	GET <code>/dashboard/stats</code> (new P2: GET <code>/dashboard/trends?months=12</code>); GET <code>/reports/monthly</code> , <code>/reports/annual</code> , <code>/reports/arrears</code>
Messages	GET/POST/PUT <code>/announcements</code> , PATCH <code>/announcements/:id/toggle</code> , DELETE; GET <code>/member-requests</code> , PATCH <code>/member-requests/:id</code> ; GET <code>/puruka-admin</code> , PATCH <code>/puruka-admin/:id/deactivate reactivate</code> , GET/POST <code>/puruka-admin/categories</code> , PATCH <code>/puruka-admin/categories/:id</code>
Attendance	GET/POST <code>/events</code> , PATCH <code>/events/:id</code> , DELETE <code>/events/:id</code> , GET/POST <code>/events/:id/attendance</code> , DELETE <code>/events/:id/attendance/:memberId</code>
Settings & misc	GET/PUT <code>/settings</code> , POST <code>/client-errors</code> , GET <code>/health</code> (gains <code>api_version</code>)
Directory (platform)	GET <code>/directory/v1/resolve/:code</code> (gains optional <code>app_url</code>)

Response shapes are unchanged; the web DTO types are ported from `src/renderer/src/types/index.ts` and checked against MSW fixtures recorded from the testbed.

6.8 State, caching and invalidation

Query keys per feature (`['members', filters]`, `['member', id]`, `['member-statement', id]`, `['members-slim']`, `['income', filters]`, `['expenses', filters]`, `['loans']`, `['loan', id]`, `['wallets']`, `['fds']`, `['assets']`, `['settings']`, `['income-types']`, `['expense-types']`, `['dashboard']`, `['reports', kind, params]`, `['events']`, `['event-attendance', id]`, `['announcements']`, `['member-requests', status]`, `['puruka', filters]`, `['puruka-categories']`, `['users']`, `['me']`, `['sessions']`).

Mutation	Invalidates
income / expense create · void · delete	ledger, dashboard, wallets, member-statement
loan issue · migrate · repay · delete	loans, loan, dashboard, wallets, income, member-statement
wallets / FDs / assets	wallets, fds, assets, dashboard

Mutation	Invalidates
settings	settings, dashboard, loans (rates)
income / expense types	types, settings
members create · update · delete · app-access	members, members-slim, member
events / attendance	events, event-attendance
announcements / requests / puruka / users / sessions	their own key

Optimistic updates only where the server cannot meaningfully disagree: attendance mark / unmark (row moves, count bumps, rollback on error — the scanner cadence needs it), announcement toggle, request review. **Money mutations are never optimistic.** Stale times: settings and members-slim 5 min, dashboard 60 s, loans 60 s with `refetchOnWindowFocus: false` (the list endpoint runs accrual writes), ledgers 30 s, reports 0. `useMigrationMode()` mirrors the server rule (`settings.migration_completed !== 'true'` once settings have loaded).

6.9 Printing

`lib/print/receipt.ts` is the desktop's `buildReceiptHtml` ported verbatim with its numbering helpers; templates are rendered into a sandboxed iframe (`srcdoc`, `sandbox="allow-same-origin allow-modals"`), styled by `print.css` (light theme, `@page` A4 or 80 mm), previewed in a Sheet and printed with `iframe.contentWindow.print()`. Snapshot tests in both languages guard the templates; visual regression compares rendered previews.

6.10 PWA

vite-plugin-pwa with `registerType: 'prompt': precache **/*.
{js,css,html,woff2,svg,png,webmanifest}`, `navigateFallback: index.html` with `navigateFallbackDenylist: [/^\/api\/$/, /^\/directory\/$]`, **no runtime caching rules** (API is always network-only), `cleanupOutdatedCaches`. Update flow: `useRegisterSW` → toast "New version available — Reload" (skipWaiting on accept). Manifest: `name / short_name eSamithi`, `id "/"`, `start_url "/"`, `display standalone`, `theme_color #1E64D4`, `background_color #0F172A`, icons 192 / 512 from `mobile/assets/images/icon.png` plus a maskable 512, `categories ["finance","productivity"]`. `beforeinstallprompt` is captured and offered only from the user menu, hidden when the UA contains `eSamithiShell/`.

6.11 Desktop 1.3.8 thin shell

`BrowserWindow` (`minWidth 1024`, `minHeight 700`, `autoHideMenuBar`, `session.fromPartition('persist:esamithi')` so the refresh cookie survives restarts) → `loadURL(process.env.ESAMITHI_WEB_URL || 'https://app.esamithi.com')`; `did-fail-load / offline` → bundled `offline.html` with `Retry`; `will-navigate` restricted to the app origin; `setWindowOpenHandler` → `shell.openExternal`; `electron-window-state`; zoom persistence; `setPermissionRequestHandler` deny-all; UA suffix `eSamithiShell/1.3.8`; native print via `window.print()`; USB keyboard-wedge scanners are plain keystrokes. Removed: `api-client.ts`, `ipc-handlers.ts`, `database.ts`, setup/directory code, the renderer bundle and the preload API except a two-line bridge (`shell: {version}`). A **silent** `autoUpdater` (auto-download, install on quit, no UI) stays as insurance; 1.3.8 ships through the existing `/updates/` feed. Rollback: publish 1.3.9 built from the frozen renderer.

7. Security requirements

Threat	Control
Token theft through XSS	Refresh token in an HttpOnly cookie; access token in memory only; strict CSP (<code>script-src 'self'</code> , no inline scripts, no third-party origins); React escaping; no <code>dangerouslySetInnerHTML</code> outside the sandboxed receipt iframe
CSRF	<code>SameSite=Strict</code> cookie scoped to <code>/api/v1/auth</code> ; <code>X-Requested-With</code> requirement; <code>Sec-Fetch-Site</code> check; business routes accept bearer tokens only
Session replay / stolen refresh token	Rotation on every refresh; reuse detection revokes the family; idle 12 h and absolute 24 h limits; per-session revoke and "sign out everywhere"
Credential stuffing / brute force	IP+tenant rate limit (30 / 15 min), account lockout (10 → 15 min, HTTP 423), generic error text, auth event log
Weak password storage	Dual verification then opportunistic bcrypt re-hash (cost 10); new and reset passwords bcrypt from Deploy B
Cross-tenant access	<code>X-Samithi + sam</code> claim check unchanged; cookie slug must equal the header; per-tenant databases unchanged
Cross-server confusion	The SPA never calls another origin; cross-server societies are redirected with an explicit message
Clickjacking / framing	<code>frame-ancestors 'none'</code> , <code>X-Frame-Options: DENY</code>
Stale or poisoned client bundles	<code>no-cache</code> HTML / service worker, immutable hashed assets, prompt-mode updates, releases as directories with symlink rollback
Privilege misuse by viewer	Server-side read-only middleware unchanged; UI hides writes; E2E test walks the role
Operator impersonation	Platform-issued short token, permanent banner, audit trail on the platform, no refresh cookie in support mode
Supply chain	Pinned dependencies, <code>npm audit</code> in CI, no CDN scripts, fonts self-hosted
Secrets	No secrets in the bundle; <code>.env</code> only on servers; <code>JWT_SECRET</code> never rotated; SSH keys and console credentials rotated after the September releases (owner action)

8. Feature-parity matrix and sign-off

Every row must pass on the testbed society `test01` and, during the pilot, on `samithi01`.

Module	Web screens / flows	Acceptance (parity)
Auth & setup	Join code → resolve → credentials; remembered samithi with "Change"; maintenance banner; other-server redirect; refresh / expiry dialog; logout; sessions; change password; support mode	Same credentials as the desktop; wrong code → directory error text; suspended → 403 text; refresh survives reload; expired refresh → dialog; reuse → all sessions dead; desktop 1.3.7 login still returns <code>{success, user, token}</code>
Dashboard	KPI grid, attention card (hidden fee check in migration mode), quick actions, cash-flow chart, recent activity, refresh	Figures identical to the desktop at the same instant; attention links land on the right arrears sub-tab; Sinhala month labels
Members	List (server search name / ID / NIC), add / edit (all fields, banks, dependents with auto-age, async uniqueness, 10-digit phone), Member 360 (profile, statement, guarantees, dependents, app access), delete (blocked with transactions), scan card, app access (admin), record-payment handoff	Every desktop validation message reproduced; scanner input keeps focus; non-admins never see app-access controls; 403 handled
Incomes	Filters, pagination 25 / 50 / 100, active total, adaptive form by type code, void with reason, delete voided, receipt INC-, CSV	Server errors surface verbatim; receipt HTML matches the desktop template in both languages; CSV opens in Excel with Sinhala intact
Expenses	As incomes plus member-benefit prefill, bill categories + payee, voucher number, insufficient-funds pre-check, voucher EXP-	Same
Loans	Portfolio (member-ID default sort, natural order; sorts; search; exposure), issue (two distinct guarantors; headroom; existing-loans panel; wallet check; limit 0 = no cap), kind chooser + migrate (as-of, next-charge preview, Defaulted), repay (waterfall, ≤ owed, active wallet), detail page (LNP- receipts, LN- statement), delete with consequence text	Allocation equals the server's; Paid → success variant; migrated badge; delete confirms with typed identifier
Wallet hub	Wallets (deposit and opening balance in migration mode only; toggle blocked with balance; delete rules), transfer, FDs (fund-from-wallet hidden in migration mode; maturing ≤ 30 d; Matured status; withdraw messages), assets CRUD	Migration gating identical to server responses
Reports	Monthly, annual (+ position), arrears (overdue / FDs / unpaid fees — note in migration mode), period pickers, letterhead print	Printed output has letterhead, no chrome, ruled tables; Sinhala titles
Messages	Announcements (death / meeting / general, deceased picker, hide / show, delete), requests (pending / all, approve / reject with note, loan hint), Puruka admin (filters, reported-only, takedown / restore, categories)	Push side-effects unchanged; statuses translated
Attendance	Events (type, title, date, mode), scan / type with OK / dup / miss feedback and refocus, mark from list, undo, mode switch confirm, search, tabs, delete	Scanner burst handling identical; counts match <code>attendee_count</code>

Module	Web screens / flows	Acceptance (parity)
Settings	General, loan engine (rupees in, cents stored), income / expense types (system types renameable, not deletable, reactivate), users (admin: create <code>admin</code> / <code>user</code> / <code>viewer</code> , delete except self / last admin, reset password), about, export JSON, security	Non-admin warning card; last-admin message
Cross-cutting	Sinhala / English everywhere incl. receipts; dark mode; migration banner; offline banner + retry; a11y	check: i18n passes; axe has no serious violations; Lighthouse budgets met

Sign-off checklist (recorded in `web/docs/PARITY-SIGNOFF.md`):

1. Every matrix row green on the testbed by two testers, one using the Sinhala UI.
2. Receipts, vouchers and statements printed side by side with desktop 1.3.7 for the same records, in English and Sinhala.
3. CSV diff of income and expense exports against the desktop for the same filter.
4. Dashboard and report figures equal at the same instant.
5. A migration-mode society (console toggle on `demo`) and a live-mode society both exercised.
6. `admin`, `user` and `viewer` roles walked through end to end.
7. `server/test/isolation.test.js`, `smoke-tenants.sh` and the new auth tests green.
8. Lighthouse and axe budgets met on the RC build.
9. Sinhala terminology review by the pilot treasurer.
10. Owner sign-off recorded with date and build hash.

9. Testing and quality strategy

Layer	Scope	Tooling / gate
Unit	<code>formatCurrency</code> / <code>parseCurrency</code> ; receipt numbering (<code>INC-00001</code> , <code>EXP-</code> , <code>LNP-</code> , <code>LN-</code>); <code>buildReceiptHtml</code> snapshots en + si; repayment waterfall; headroom rules (limit 0 disables; principal-only exposure); migrate next-charge preview (month-end clamp); date presets; <code>formatDate</code> never shifts a day; CSV escaping + BOM; i18n key parity + <code>{placeholder}</code> parity; Zod schemas (two distinct guarantors, phone, cents); host-map redirect; session manager (single flight, retry once, lock); Sinhala font glyph coverage (open the woff2 with fontkit, assert glyphs for every Sinhala dictionary value shape without <code>.notdef</code>)	Vitest; blocks the build
Component	<code>RupeelInput</code> , <code>MemberPicker</code> , <code>DataTable</code> , <code>ConfirmDialog</code> typed confirmation, <code>SessionDialog</code> re-auth + retry, adaptive income form per code, migration-mode gating of wallet / FD / loan UI, <code>viewer</code> hides writes	Testing Library + MSW
E2E — PR lane	Deterministic flows against <code>vite preview</code> with MSW browser mocks: login, record income → print (stub <code>window.print</code> , assert receipt DOM + language), void, expense with voucher, issue → repay → statement, wallet / FD / asset, attendance scan (type + Enter, dup, unknown, absent mode), messages, settings users, Sinhala switch, refresh after reload	Playwright (Chromium, Firefox, WebKit)
E2E — testbed lane	Nightly and on <code>main</code> against <code>https://console.esamithi.com/app/</code> (<code>test01 admin/admin123</code> ; <code>demo = DEM-9361</code>): the same flows plus other-server redirect, real rotation with <code>STAFF_ACCESS_TTL=1m</code> , reuse detection, lockout after 10 failures → 423, <code>/auth/login</code> desktop contract unchanged	Playwright <code>@testbed</code> tag
Accessibility	Axe on every route; keyboard-only pass	<code>@axe-core/playwright</code> ; serious / critical fail
Visual regression	Receipt / voucher / statement previews in en + si; login and dashboard in light / dark	Playwright <code>toHaveScreenshot</code> (fonts bundled → deterministic)
Server	<code>test/isolation.test.js</code> kept green; new <code>test/staffAuth.test.js</code> (fake pool: dual verify, lockout counters, rotation / reuse / leeway, cookie parsing); <code>test/ci-auth-e2e.sh</code> (curl flows against the CI MySQL boot); <code>api.yml</code> lists test files explicitly	Node 20 <code>--test</code>
Performance	Lighthouse CI budgets (LCP < 2.5 s, TBT < 200 ms, CLS < 0.1); bundle size check (initial JS ≤ 250 KB gzip, fonts ≤ 350 KB)	Lighthouse CI on <code>main</code> builds
Load	Synthetic 5,000-member tenant on the testbed; member search, ledger paging and reports under 20 concurrent users	k6 script, Phase 3
Manual	Counter-day rehearsal on the testbed (two testers, scanner, printer); pilot office pass on their own PC and printer	Logged in the sign-off file

10. Delivery plan

Indicative durations for one developer working with an AI pair (≈ 12–13 development weeks plus pilot calendar time). Phases 0–3 never touch the production server.

Phase	Scope	Entry	Exit criteria
0 • Foundations (1.5–2 wk)	This document; <code>web/</code> scaffold; tokens + shadcn; i18n sync + check; fonts; API client + session manager; login flow; backend items B1–B10 (\$A) with tests; testbed <code>/app/</code> host + CI; MSW; Playwright smoke	Design approved	Login via join code on <code>console.esamithi.com/app/</code> against <code>test01</code> ; rotation / reuse / lockout tests green; desktop 1.3.7 login unchanged on the testbed; Lighthouse baseline recorded
1 • Core money (3 wk)	Dashboard, Members + Member 360, Incomes, Expenses, Wallet hub, receipts / vouchers, CSV, banners	Phase 0 exit	Matrix rows green for these modules; receipts diffed against the desktop in en + si; counter-day rehearsal on the testbed
2 • Remaining modules (3 wk)	Loans, Reports, Settings (users / roles, change password, sessions), Attendance, Messages, all migration-mode variants, statements	Phase 1 exit	Full matrix green; Sinhala terminology review scheduled
3 • Polish & hardening (2 wk)	Command palette, scan sink, tablet layouts, dark / print QA, a11y, budgets, PWA, CSP / HSTS + CORS enforcement on the testbed, visual regression, load test, docs	Phase 2 exit	<code>web-v1.0.0-rc</code> tagged; sign-off items 1–8 done
4 • Pilot & cut-over (2–3 wk calendar)	DNS + certificate + gated vhost; production Deploy A after backup; migrations 014 / 015 verified on <code>samithi01</code> ; preview week; pilot with Maranadhara Samithi side by side with 1.3.7; fixes; gate removed; Deploy B (<code>PASSWORD_REHASH=on</code>) after two clean weeks; <code>STAFF_LOCKOUT_SCOPE=all</code>	RC + owner go	Pilot sign-off (items 9–10); desktop feature freeze declared
5 • Shell & end of life (1 wk + fade)	1.3.8 thin shell via the update feed; adoption watched through the shell UA in nginx logs; console handoff to <code>/support</code> ; <code>/workspace/</code> retired; later, the frozen renderer deleted	Cut-over	≥ 90 % of office sessions on web or shell; workspace removed

Milestones the owner will see: M0 requirements approved (this document) · M1 first login on the QA host · M2 counter-day rehearsal · M3 full parity demo · M4 release candidate · M5 pilot start · M6 cut-over · M7 shell release.

Definition of done for every feature: matrix row green · unit and component tests · E2E flow in the PR lane · both languages · dark mode · keyboard pass · empty and error states · docs updated.

11. Deployment, operations and production-safety protocol

11.1 Hosting and release mechanics

- **Static SPA** built by CI (`web/dist`), shipped as a tarball, unpacked into `/opt/esamithi-stack/app/releases/<version>--<sha>`, activated by flipping the relative `current` symlink and reloading nginx (`deploy/prod/deploy-web.sh` : `tar` → `release dir` → `symlink` → `curl` smoke of `/`, `/index.html` headers and `/api/v1/health`). The previous three releases are kept for rollback.
- **Testbed** receives every `main` build automatically (`.github/workflows/web.yml` : `typecheck` → `unit` → `check:i18n` → `build` → Playwright PR lane → `deploy /app/` → testbed E2E lane). Production has **no continuous deployment**: a human runs `deploy-web.sh` after the protocol below.
- **TLS**: `enable-app-tls.sh` issues `app.esamithi.com` into the existing certbot volume; the existing renew cron covers it. Owner action: DNS A record `app.esamithi.com` → `141.147.75.132` before Phase 4; confirm OCI security list allows 443 (already open for `api.esamithi.com`).
- **Monitoring**: Uptime Kuma monitors for `https://app.esamithi.com/` and `/api/v1/health`; `health-alert.sh` extended to the app URL; nginx 5xx watched during deploy windows.

11.2 Production safety protocol (every server change)

1. Lands on the testbed through CI and soaks **≥ 3 days** with the E2E suite green.
2. Announced maintenance window agreed with the pilot office (outside collection days).
3. `bash deploy/prod/backup.sh` → fresh `mysqldump` of every tenant database, plus a timestamped copy of `/opt/esamithi-server`.
4. Staged deploy (`stage-prod.sh` pattern) → `docker compose exec -T api node migrate.js`; output checked for `014` / `015` on `samithi01`.
5. Smoke: deep health, `smoke-tenants.sh`, **desktop 1.3.7 login** (`POST /auth/login` returns `{success, user, token}`), web login → refresh → logout → lockout on a test user.
6. 30-minute watch of nginx 5xx, Kuma and `health-alert.sh`.
7. Rollback triggers: any desktop login failure, degraded health, a 5xx spike, or any report from the pilot office.

11.3 Rollback

Layer	Action	Notes
API	Restore the timestamped copy of <code>/opt/esamithi-server</code> , <code>docker compose up -d --build api</code>	New tables / columns are inert for the old build; never roll back below Deploy A once re-hashing is on
SPA	Flip <code>current</code> to the previous release, <code>docker compose exec nginx nginx -s reload</code>	Seconds; no data involved
Preview gate	Re-enable <code>auth_basic</code> on <code>/</code>	Hides the app without touching the API
Desktop shell	Publish 1.3.9 built from the frozen renderer through the update feed	1.3.7 installer stays downloadable

Layer	Action	Notes
DNS	Never changed during rollback	—

11.4 Feature flags and environment

Flag	Default	Purpose
STAFF_ACCESS_TTL	15m	Access token lifetime
STAFF_REFRESH_HOURS / STAFF_SESSION_MAX_HOURS	12 / 24	Idle and absolute session limits
STAFF_LOCKOUT_MAX_FAILS / STAFF_LOCKOUT_MINUTES	10 / 15	Lockout thresholds
STAFF_LOCKOUT_SCOPE	web	web (only /auth/session) or all (desktop too, after cut-over)
PASSWORD_REHASH	off	Deploy B switch for opportunistic bcrypt re-hash
CORS_ALLOWED_ORIGINS	unset (= today)	Allow-list once observed origins are logged
VITE_BASE , VITE_API_ORIGINS , VITE_PWA	/ , prod origins, on	Build-time SPA configuration
nginx auth_basic	on during preview	Private preview gate

12. Risks and mitigations

Risk	Mitigation
Sinhala rendering differences across browsers / OS	Unsubsetting Noto Sans Sinhala woff2 self-hosted, font-coverage test, <code>:lang(si)</code> rules, native review before GA
Printed output differs between Chromium versions or printers	Visual regression of previews, explicit <code>@page</code> margins, light theme forced, Chrome / Edge recommended, pilot prints compared with the desktop
Cookie pitfalls (Secure on HTTPS only, path scoping, two-tab races)	Same-origin topology; <code>localhost</code> is treated as secure by Chrome for dev; Web Locks single flight + 5 s reuse leeway
Confusion between servers	Explicit redirect message; <code>servers.app_url</code> registry field; host map fallback
<code>JWT_SECRET</code> cannot be rotated	Access tokens are now ≤ 15 min; per-server secrets already exist; rotation runbook documented, out of scope
<code>trust proxy</code> change alters <code>req.ip</code>	Only affects logging and limiter keys; verified through morgan output on the testbed first
<code>GET /loans</code> accrues on read under aggressive refetch	60 s stale time, no focus refetch, single portfolio query
Service worker pins users to stale code	Prompt-mode updates, <code>no-cache</code> HTML and <code>sw.js</code> , API denylist, releases as directories
Office hardware (old laptops, 1366×768)	Performance budgets, icon-rail layout at 1024–1279, tested on the pilot PC
Scope creep during parity	The matrix is the contract; P2 / P3 items are tracked separately and never block the pilot
Data safety	No destructive migration; additive only; backups before every production deploy; the same business endpoints as the desktop, so no data migration exists

13. Open decisions and owner actions

Defaults below are applied unless the owner objects before Phase 0 ends.

Item	Default / status
Refresh session limits	Idle 12 h, absolute 24 h
Lockout thresholds	10 failures → 15 minutes
<code>viewer</code> role in the Users UI	Yes, selectable
CSV headers	Localised to the UI language (English exports remain one language switch away)
Rows per page for members	15 default (desktop parity), 30 / 50 selectable
Owner action: DNS	Add A record <code>app.esamithi.com</code> → <code>141.147.75.132</code> before Phase 4
Owner action: pilot office check	Confirm browsers in the office (Chrome / Edge versions), printer model, and that the USB scanner ends reads with Enter (not Tab)
Owner action: credentials	Rotate the production SSH key and console password / TOTP after the September releases (unrelated to this programme but pending)
Could not verify	Whether the live testbed compose / nginx match the repo copies (live slug <code>demo</code> vs repo <code>demo02</code>); OCI security list for 443 on the app host; production <code>.env</code> values

Appendix A · Backend work list (all additive)

#	File	Change
B1	server/migrations/index.js	Append 014_staff_sessions and 015_staff_auth_events, INFORMATION_SCHEMA-guarded
B2	server/lib/passwords.js (new)	verify (bcrypt or legacy SHA-256), hash, needsRehash, PASSWORD_REHASH flag; imported by auth.routes.js, users.routes.js, internal.routes.js, scripts/provision-tenant.js; test/ci-e2e.sh seeds through it
B3	server/lib/staffSessions.js (new)	issue, rotate, revokeUser, revokeToken, reuse detection with 5 s leeway, cookie helpers (__Secure- prefix behind HTTPS)
B4	server/lib/staffAuth.js (new)	findForLogin, recordFailure / recordSuccess (lockout thresholds from env), assertNotLocked
B5	server/middleware/rateLimit.js (new)	staffLoginLimiter, refreshLimiter (IP + tenant keys, skipSuccessfulRequests)
B6	server/routes/auth.routes.js	Limiter on /login; new /session, /refresh, /logout, /me, /sessions, /change-password; /login body untouched apart from the shared verify helper and bookkeeping
B7	server/routes/users.routes.js	PATCH /:id/password (admin); validate role ∈ {admin, user, viewer}; revoke sessions on delete
B8	server/routes/internal.routes.js	Revoke sessions on reset-password and disable
B9	server/server.js	app.set('trust proxy', 1), cookie-parser, env-gated CORS allow-list (lib/cors.js), api_version on shallow /health
B10	server/package.json, .env.example	Add cookie-parser; document the STAFF_*, PASSWORD_REHASH, CORS_ALLOWED_ORIGINS variables
B11	server/routes/dashboard.routes.js	P2 GET /dashboard/trends?months=12
B12	platform/db.js, platform/routes/servers.routes.js, resolve handler	Additive servers.app_url, surfaced in the resolve response (Phase 4/5)
B13	src/admin/lib/enter.ts	Handoff to \${app_url}/support (Phase 5)

Appendix B · Infrastructure work list

#	Item
I1	deploy/prod/nginx/app.conf.disabled — app vhost (TLS, static releases, /api/, /directory/, security headers include, preview gate)
I2	deploy/prod/enable-app-tls.sh — certificate issuance without touching the renew cron
I3	deploy/prod/docker-compose.yml — /opt/esamithi-stack/app:/srv/app:ro mount
I4	deploy/prod/deploy-web.sh — release directory, symlink flip, smoke, retention of three releases
I5	deploy/testbed/nginx/console.conf.disabled — /app/ locations; testbed compose ./app:/srv/app:ro
I6	.github/workflows/web.yml — typecheck, unit, check:i18n, build, Playwright PR lane, testbed deploy on main, testbed E2E lane, Lighthouse CI

#	Item
17	Uptime Kuma monitors and <code>health-alert.sh</code> for the app URL
18	<code>docs/</code> runbooks: web release, rollback, preview gate, DNS / TLS

Appendix C · Web package scripts and conventions

Script	Purpose
<code>npm run dev</code>	Vite dev server with <code>/api</code> and <code>/directory</code> proxied to the testbed (cookies work on <code>localhost</code>)
<code>npm run build / build:testbed</code>	Production build (<code>VITE_BASE=/</code>) / QA build (<code>VITE_BASE=/app/</code>)
<code>npm run typecheck, lint, test, test:e2e</code>	Gates run by CI
<code>npm run sync:i18n, check:i18n</code>	Generate dictionaries from the desktop source; verify parity
<code>npm run fonts:build</code>	Regenerate woff2 from the TTFs in <code>mobile/assets/fonts</code>

Conventions: feature folders own their API, queries, schemas and components; UI primitives are owned code; no default exports outside routes; every user-visible string goes through `t()`; money is always integer cents at the boundary; dates are ISO strings; no `any` in `lib/`.

Appendix D · Glossary

Term	Meaning in eSamithi
Samithi / society	A community welfare (funeral aid) society; one tenant, one database, one join code such as <code>SAM-4217</code>
Join code	Public code a device enters once to find its society through the directory
Migration mode	Society is still entering historical balances; wallets accept deposits and opening balances, existing loans can be migrated; ends when <code>migration_completed = 'true'</code>
Headroom	<code>max_loan_limit - outstanding_principal</code> across a member's Active / Overdue loans; the most a new loan can be
Waterfall	Repayment allocation order: fines → interest → principal
Puruka	The in-app member marketplace administered by the office
Support mode	An operator's audited, time-boxed session inside a society's workspace
Thin shell	Desktop 1.3.8: an Electron window that loads the web app and nothing else

Appendix E · Reference files in the repository

`src/renderer/src/workspace/shim.ts` (REST contract) · `src/renderer/src/utis/print.ts`, `formatters.ts`, `members.ts` (ported utilities) · `src/renderer/src/i18n/{en,si}.ts` (dictionaries) · `server/routes/auth.routes.js`, `server/middleware/auth.js`, `server/middleware/tenant.js` (auth

today) · `server/migrations/index.js` (migration pattern) · `deploy/prod/nginx/api.conf.disabled` ,
`deploy/testbed/nginx/console.conf.disabled` (nginx templates) · `deploy/prod/backup.sh` , `stage-`
`prod.sh` , `enable-api-tls.sh` (production runbooks) · `.github/workflows/api.yml` , `clients.yml` (CI
patterns) · `mobile/assets/images/icon.png` , `mobile/assets/fonts/` (brand assets).

End of document.